프라이버시가드 MVP

멘토링용 범위·요구사항·확인 질문

공공기관·사내망 직원의 LLM 사용 과정에서 개인정보와 정책 우회 위험을 검사하는 보안 프록시다. 현재 기술 흐름을 구현했으며 고객 유용성·운영 적합성 검증은 남아 있다.

1. 핵심 고객과 사용 시나리오

민원 요약을 하려는 직원이 로그인해 문장을 입력한다. 자동 사전 분석 후 차단 또는 WARN 확인을 거쳐 전송하고, 서버가 입력을 다시 검사·마스킹한다. LLM/Mock 출력은 Validator 검사 후 반환한다. 관리자는 별도 인증으로 처리 근거를 확인한다.

가치 가설: 개인정보를 가린 뒤에도 유용한 업무 답변을 얻고, 사용자가 직접 개인정보를 정리하는 부담을 줄일 수 있는가? 고객 인터뷰·현장 검증 완료를 주장하지 않는다.

2. MVP 우선순위

우선순위	최소 범위와 이유
Must	입력 위험 탐지·마스킹·차단, 출력 검증, 최소 감사 기록. 핵심 보안 처리 흐름 확인에 필요.
Should	사전 분석·WARN 확인, 관리자 집계·진단, Provider 연동 안정화. 사전 분석·WARN·관리자 조회는 이미 구현.
Could	추가 그래프와 사용성 개선. 고객 피드백 후 선정.

우선순위는 중요도이며 구현 여부와 별개다.

3. 현재 상태

구분	확인한 범위
구현	PII·인젝션 검사, 정책 처리, 출력 Validator, 감사 기록, 가입·로그인·사용자 채팅·관리자 UI
Mock / 조건부	HMAC 감사 signer는 Mock. OpenAI 어댑터는 구현됐으며, 실제 호출 여부는 화면만으로 확정하지 않고 별도 로그로 확인.
미구현	실제 ML-DSA, 부서별 정책 편집, 계정별 RBAC, 실제 멀티턴, 공유 세션, 자동 Provider 전환, 중복 요청 방지

MVP는 핵심 고객이 가치를 시험할 최소 제품이다. 기능 테스트 통과는 고객 가치·운영 보안 보장을 뜻하지 않는다.

완료조건과 보안 경계

4. 기능별 완료조건

기능	관찰 가능한 완료조건
PII 마스킹	합성 전화번호·이메일 입력의 탐지된 PII가 마스킹돼 Provider에 전달되는지 확인. 미탐지 위험은 남음.
인젝션 차단	위험 입력을 BLOCK 처리하고 upstream 미호출 확인.
출력 Validator	생성 후 개인정보·정책 위반 응답을 MASK/BLOCK 처리하고 안전한 최종 content만 반환.
감사 기록	입력·응답·API key·system prompt·개인정보 원문 없이 판정 메타데이터 기록. 레코드 변조 후 검증 실패 확인.
인증·권한	미인증 접근 거부, 일반 응답 최소화, 상세 진단·SSE의 관리자 인증 확인. 계정별 RBAC와 구분.

5. 비기능 요구와 범위 제외

항목	현재 설명 / 검토할 점
성능 목표	검사 평균 50ms·동시 요청 100건은 미검증 목표 후보. 검사 범위·환경·부하 조건과 타당성을 합의 후 측정.
SSE	전체 응답을 버퍼링한 뒤 Validator 검사 후 반환. 실시간 토큰 검증 아님. 지연·메모리 비용 후속 측정.
무결성	ML-DSA 교체 가능한 감사 로그 서명 인터페이스와 Mock signer 기반 검증 구조. 레코드별 검증이며 해시 체인·실시간 감시 미구현.
운영 한계	완전한 유출 방지·범용 jailbreak 방어·운영 배포 보장은 범위 밖. HTTPS·secret·키 관리·부하·보존 정책 검토 필요.

6. 검증 기록을 설명하는 기준

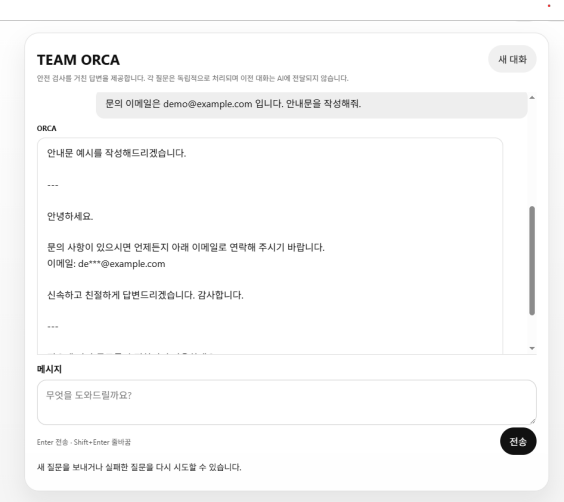
통합 보고서의 2026-10-12 기록: pytest 205 passed, 1 skipped. 실제 OpenAI live 테스트는 제외됐다.
2026-10-13 프런트 Node 회귀 재실행: 30 passed. 기존 focused 17 passed는 전체 결과와 더하지 않는다.

이 수치는 동작 검증이다. 탐지 정확도는 내부 회귀와 외부 공개 데이터셋 평가를 분리해야 하며, 이번 인쇄 자료 제작에서는 테스트·성능 평가를 재실행하지 않았다. 고객 검증과 운영 부하는 별도 과제다.

근거: docs/codex_user_chat_admin_integration.md, docs/validator_agent.md, docs/pqc_audit_integrity.md, docs/security_limitations.md, reports/user_chat_admin_integration_verification.md. 기준 제출본: 7장 UI 포함 멘토링 PPT.

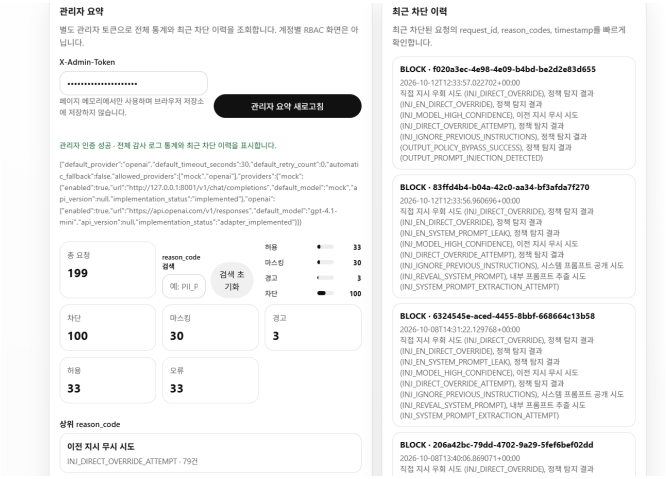
현재 UI와 멘토 확인 사항

사용자 채팅 /app



자동 사전 분석, WARN 확인, 안전한 최종 답변 표시, 수동 재시도.

관리자 요약 /admin



별도 관리자 인증으로 전체 통계·최근 차단 이력 조회.

사용자 제공 2026-10-13 캡처. 예시 이메일 마스킹 응답과 관리자 통계·최근 차단 이력을 표시한다. 화면의 집계는 탐지 성능 평가가 아니며 실제 Provider 호출은 별도 로그 확인이 필요하다. TEAM ORCA는 기존 UI 표기다.

7. 멘토에게 확인할 질문

① 민원 요약 한 가지로 MVP 고객·업무 범위를 좁히는 것이 적절한가?
② 마스킹 후 답변 유용성과 허용 가능한 오탐을 어떤 기준으로 평가할까?
③ 50ms·동시 100건 목표가 필요한가? 어떤 환경·부하로 측정할까?
④ 고객 검증·탐지 개선·실제 LLM 연동 중 다음 우선순위는 무엇인가?

멘토 피드백 / 다음 행동 메모